

Lezione 3 – Cyber-Physical Security

Strategie di Sicurezza e Vulnerabilità

Dario Stabili

Corso di Laurea Triennale in Ingegneria Informatica – Sede di Mantova

Dipartimento di Ingegneria “Enzo Ferrari” (DIEF)

Università degli Studi di Modena e Reggio Emilia

a.a. 2025–2026



UNIMORE
UNIVERSITÀ DEGLI STUDI DI
MODENA E REGGIO EMILIA

Problema: come ci si difende da un attacco?

Basta la definizione di un'architettura di rete sicura, l'isolamento e la protezione degli host critici e il monitoraggio continuo della rete per effettivamente proteggersi da un attacco informatico?

Problema: come ci si difende da un attacco?

Basta la definizione di un'architettura di rete sicura, l'isolamento e la protezione degli host critici e il monitoraggio continuo della rete per effettivamente proteggersi da un attacco informatico?

CERTAMENTE

Problema: come ci si difende da un attacco?

Basta la definizione di un'architettura di rete sicura, l'isolamento e la protezione degli host critici e il monitoraggio continuo della rete per effettivamente proteggersi da un attacco informatico?

CERTAMENTE **NO**

Strategie di sicurezza

- Esistono diverse strategie di sicurezza che permettono di proteggersi costantemente da attacchi informatici:
 - **Cyber Kill Chain**
 - **MITRE ATT&CK**

Strategie di sicurezza

- Esistono diverse strategie di sicurezza che permettono di proteggersi costantemente da attacchi informatici:
 - **Cyber Kill Chain**
 - **MITRE ATT&CK**
- Entrambe si basano sullo stesso presupposto: **capire come opera l'attaccante per contrastarlo**

Cyber Kill Chain

Cyber Kill Chain

Il **Cyber kill chain** è un modello definito dalla Lockheed Martin, per l'identificazione e la prevenzione delle attività di intrusione informatica attraverso l'implementazione di protocolli di sicurezza pro-attivi. Tale modello è a sua volta ispirato al *kill chain*, un modello militare che identifica diverse fasi di attacco

Cyber Kill Chain

(Fasi dell'attacco – 1. Reconnaissance)



- **Reconnaissance (Ricognizione)**
- L'attaccante identifica il target, ottiene informazioni su di esso (OSINT, network mapping, social engineering, ecc.) e prova ad identificare vulnerabilità nella rete o nei sistemi dell'organizzazione.

Cyber Kill Chain

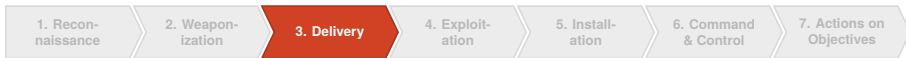
(Fasi dell'attacco – 2. Weaponization)



- **Weaponization (Armamento)**
- L'attaccante crea un'arma malware appositamente progettata per le vulnerabilità identificate sulla rete (es. accoppiando un exploit con un payload malevolo all'interno di un documento o eseguibile).

Cyber Kill Chain

(Fasi dell'attacco – 3. Delivery)



- **Delivery (Consegna)**
- L'attaccante trasmette l'arma al target attraverso vari vettori di attacco (allegati e-mail di phishing, siti web compromessi, dispositivi USB esterni o servizi esposti).

Cyber Kill Chain

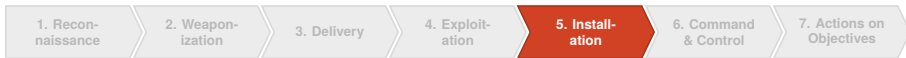
(Fasi dell'attacco – 4. Exploitation)



- **Exploitation (Esecuzione dell'exploit)**
- Il codice dell'arma malware viene attivato sul sistema vittima, andando a sfruttare la vulnerabilità software per eseguire codice arbitrario.

Cyber Kill Chain

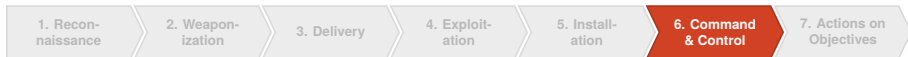
(Fasi dell'attacco – 5. Installation)



- **Installation (Installazione)**
- L'arma malware installa un punto d'accesso nascosto e permanente ("backdoor", trojan o webshell) che l'attaccante può sfruttare per mantenere l'accesso al sistema.

Cyber Kill Chain

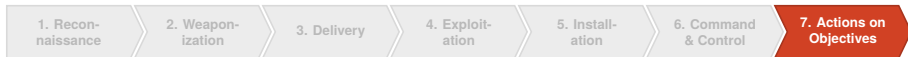
(Fasi dell'attacco – 6. Command & Control)



- **Command & Control (C2 / Comando e Controllo)**
- Il malware abilita l'attaccante a mettere “mano” sul sistema da remoto, instaurando un canale di comunicazione con la propria infrastruttura e ottenendo persistenza nella rete vittima.

Cyber Kill Chain

(Fasi dell'attacco – 7. Actions on Objectives)



- **Actions on Objectives (Azioni sugli Obiettivi)**
- L'attaccante può controllare direttamente l'host compromesso per i propri scopi: esfiltrazione di dati riservati, distruzione di risorse o cifratura dei file per richiesta di riscatto (ransomware).

Cyber Kill Chain

(Panoramica Generale)



Comprendere la struttura sequenziale della **Cyber Kill Chain** permette ai difensori di bloccare l'attacco in uno qualsiasi dei suoi passaggi iniziali prima che raggiunga l'obiettivo finale ("break the chain").

The image features a solid dark red background. Two thick, light red curved lines are positioned on the left and bottom right sides, framing the central text. The text "MITRE ATT&CK" is written in a bold, white, sans-serif font, centered horizontally and partially overlaid by the left curved line.

MITRE ATT&CK

MITRE ATT&CK

- Il **MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge framework)** è un catalogo omnicomprendensivo di tutte le principali procedure usate dagli attaccanti per:
 - Enumerare sistemi
 - Violare sistemi
 - Rendere persistente l'accesso ai sistemi
- Homepage del progetto: <https://attack.mitre.org/>
- **MITRE**: ente no-profit finanziatore della ricerca a livello governativo americano

Tattiche di attacco

(Illustrano gli obiettivi degli attaccanti)

- Le procedure di attacco sono suddivise in **tattiche**.
- **Tattica:** è un obiettivo finale dell'attaccante, motivo principale delle sue azioni
- La tattica rappresenta il *perché* delle azioni svolte.
- Raccoglie tutte le azioni che condividono una finalità
- Fornisce una visione dell'attacco “ad alto livello”

Tattiche di attacco

(Illustrano gli obiettivi degli attaccanti)

- Ogni tattica di attacco contiene diverse **tecniche**.
- **Tecnica:** è un'azione concreta volta ad uno specifico obiettivo.
- La tecnica rappresenta il *compendio* delle azioni svolte.
- Specifica cosa ottiene un attaccante al termine della stessa
- È un “mattoncino di base” (building block) a disposizione dell'attaccante per il conseguimento di uno specifico obiettivo
- Per una tattica possono esistere diverse tecniche

ATT&CK Matrix

(Correla tattiche e tecniche)

La **ATT&CK Matrix** correla in modo efficace le **tattiche** (disposte nelle intestazioni di colonna) con le corrispettive **tecniche** (disposte verticalmente sotto ciascuna tattica):



ATT&CK Matrix

(Correla tattiche e tecniche)

- Esistono tre tipi di matrici ATT&CK:
- Enterprise (per sistemi tradizionali e tecnologie cloud)
- Mobile (per sistemi di comunicazione mobili)
- ICS (per sistemi di controllo industriale)
- All'interno di ogni matrice, è possibile selezionare la piattaforma di riferimento (sistema operativo, applicazione) e vedere la lista di tecniche e sotto-tecniche che possono essere applicate.

Enterprise	^
PRE	
Windows	
macOS	
Linux	
Cloud	v
Network	
Containers	
Mobile	^
Android	
iOS	
ICS	

Tipologie di Matrici

(Enterprise - <https://attack.mitre.org/matrices/enterprise/>)

● 14 Tattiche:

- Reconnaissance
- Resource Development
- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion
- Credential Access
- Discovery
- Lateral Movement
- Collection
- Command and Control
- Exfiltration
- Impact



(Mobile - <https://attack.mitre.org/matrices/mobile/>)

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion
- Credential Access
- Discovery
- Lateral Movement
- Collection
- Command and Control
- Exfiltration
- Impact
- Network Effects
- Remote Service Effects

[illegible]

Tipologie di Matrici

(ICS - <https://attack.mitre.org/matrices/ics/>)

● 12 Tattiche:

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Evasion
- Discovery
- Lateral Movement
- Collection
- Command and Control
- Inhibit Response Function
- Impair Process Control
- Impact

Initial Access	Execution	Persistence	Privilege Escalation	Evasion	Discovery	Lateral Movement	Collection	Command and Control	Inhibit Response Function	Impair Process Control	Impact
12 techniques	12 techniques	6 techniques	2 techniques	7 techniques	5 techniques	7 techniques	11 techniques	3 techniques	14 techniques	14 techniques	12 techniques
Stealthy Compromise	Autonomous Image	Hardcoded Credentials	Exploitation for Privilege Escalation	Change Operating Mode	Network Enumeration	Default Credentials	Adversary in the Middle	Commonly Used Port	Activate Firmware Update Mode	Bypass Force I/O	Damage to Property
Repeat Public Facing Application	Change Command Mode	Modify Program	Masking	Exploitation for Privilege	Network Sniffing	Exploitation of Remote Services	Automated Collection	Connection Proxy	Alarm Suppression	Modify Parameters	Denial of Control
Exploitation of Remote Services	Compromised User Interface	Malware Firmware	Module	Indoctrination of Host	Remote System Discovery	Hardcoded Credentials	Data from Information Repositories	Standard Application Layer Protocol	Block Command Message	Malware Firmware	Denial of View
Extended Remote Services	Exploitation through API	Project File Injection		Masking					Block Reporting Message	Spooft Reporting Message	Loss of Availability
Internet Accessible Device	Graphical User Interface	System Firmware		Roadkill	Remote System Information Discovery	Program Download	Detect Operating Mode		Change Credential	Unauthorized Command Message	Loss of Productivity and Revenue
Remote Services	Modifying Controller Settings	Valid Accounts		Spooft Reporting Message	Workarea Sniffing	Remote Services	I/O Image		Data Destruction		Loss of Protection
Replication Through Removable Media	Native API			System Binary Proxy Execution		Valid Accounts	Monitor Process State		Denial of Service	Device Restart/Shutdown	Loss of Safety
Rogue Master	User Execution						Point & Tag Identification		Device Restart/Shutdown	Manipulate I/O Image	Loss of View
Spoofting Attachment							Program Upload		Modify Alarm Settings		Manipulation of Control
Supply Chain Compromise							Screen Capture		Roadkill		Manipulation of View
Transient Cyber Asset							Wireless Sniffing		Service Stop		Theft of Operational Information
Wireless Compromise									System Firmware		

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

Initial Access	Execution	Persistence	Privilege Escalation	Evasion	Discovery	Lateral Movement	Collection	Command and Control	Inhibit Response Function	Impair Process Control	Impact
12 techniques	10 techniques	6 techniques	2 techniques	7 techniques	5 techniques	7 techniques	11 techniques	3 techniques	14 techniques	5 techniques	12 techniques
Drive-by Compromise	Autorun Image	Hardcoded Credentials	Exploitation for Privilege Escalation	Change Operating Mode	Network Connection Enumeration	Default Credentials	Adversary-in-the-Middle	Commonly Used Port	Activate Firmware Update Mode	Brute Force I/O	Damage to Property
Exploit Public-Facing Application	Change Operating Mode	Modify Program	Hooking	Exploitation for Evasion	Network Sniffing	Exploitation of Remote Services	Automated Collection	Connection Proxy	Alarm Suppression	Modify Parameter	Denial of Control
Exploitation of Remote Services	Command-Line Interface	Module Firmware		Indicator Removal on Host	Remote System Discovery	Hardcoded Credentials	Data from Information Repositories	Standard Application Layer Protocol	Block Command Message	Module Firmware	Denial of View
External Remote Services	Execution through API	Project File Infection		Masquerading	Remote System Information Discovery	Lateral Tool Transfer	Data from Local System		Block Reporting Message	Spoof Reporting Message	Loss of Availability
Internet Accessible Device	Graphical User Interface	System Firmware		Rootkit	Wireless Sniffing	Program Download	Detect Operating Mode		Block Serial COM	Unauthorized Command Message	Loss of Control
Remote Services	Hooking	Valid Accounts		Spoof Reporting Message	System Binary Proxy Execution	Remote Services	I/O Image		Change Credential		Loss of Productivity and Revenue
Replication Through Removable Media	Modify Controller Tasking					Valid Accounts	Monitor Process State		Data Destruction		Loss of Protection
Rogue Master	Native API						Point & Tag Identification		Denial of Service		Loss of Safety
Spearphishing Attachment	Scripting						Program Upload		Device Restart/Shutdown		Loss of View
Supply Chain Compromise	User Execution						Screen Capture		Manipulate I/O Image		Manipulation of Control
Transient Cyber Asset							Wireless Sniffing		Modify Alarm Settings		Manipulation of View
Wireless Compromise									Rootkit		Theft of Operational Information
									Service Stop		
									System Firmware		

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

[Home](#) > [Techniques](#) > [ICS](#) > [Change Operating Mode](#)

Change Operating Mode

Adversaries may change the operating mode of a controller to gain additional access to engineering functions such as Program Download. Programmable controllers typically have several modes of operation that control the state of the user program and control access to the controllers API. Operating modes can be physically selected using a key switch on the face of the controller but may also be selected with calls to the controllers API. Operating modes and the mechanisms by which they are selected often vary by vendor and product line. Some commonly implemented operating modes are described below:

- Program - This mode must be enabled before changes can be made to a devices program. This allows program uploads and downloads between the device and an engineering workstation. Often the PLCs logic is halted, and all outputs may be forced off. ^[1]
- Run - Execution of the devices program occurs in this mode. Input and output (values, points, tags, elements, etc.) are monitored and used according to the programs logic. [Program Upload](#) and [Program Download](#) are disabled while in this mode. ^[2] ^[3] ^[1] ^[4]
- Remote - Allows for remote changes to a PLCs operation mode. ^[4]
- Stop - The PLC and program is stopped, while in this mode, outputs are forced off. ^[3]
- Reset - Conditions on the PLC are reset to their original states. Warm resets may retain some memory while cold resets will reset all I/O and data registers. ^[3]
- Test / Monitor mode - Similar to run mode, I/O is processed, although this mode allows for monitoring, force set, resets, and more generally tuning or debugging of the system. Often monitor mode may be used as a trial for initialization. ^[2]

ID: T0858

Sub-techniques: No sub-techniques

① Tactics: [Execution](#), [Evasion](#)

① Platforms: None

Version: 1.0

Created: 21 May 2020

Last Modified: 13 October 2023

[Version](#) [Permalink](#)

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

[Home](#) > [Techniques](#) > [ICS](#) > [Change Operating Mode](#)

Change Operating Mode

Adversaries may change the operating mode of a controller to gain additional access to engineering functions such as Program Download. Programmable controllers typically have several modes of operation that control the state of the user program and control access to the controllers API. Operating modes can be physically selected using a key switch on the face of the controller but may also be selected with calls to the controllers API. Operating modes and the mechanisms by which they are selected often vary by vendor and product line. Some commonly implemented operating modes are described below:

- Program - This mode must be enabled before changes can be made to a devices program. This allows program uploads and downloads between the device and an engineering workstation. Often the PLCs logic is halted, and all outputs may be forced off. ^[1]
- Run - Execution of the devices program occurs in this mode. Input and output (values, points, tags, elements, etc.) are monitored and used according to the programs logic. [Program Upload](#) and [Program Download](#) are disabled while in this mode. ^{[2] [3] [1] [4]}
- Remote - Allows for remote changes to a PLCs operation mode. ^[4]
- Stop - The PLC and program is stopped, while in this mode, outputs are forced off. ^[3]
- Reset - Conditions on the PLC are reset to their original states. Warm resets may retain some memory while cold resets will reset all I/O and data registers. ^[3]
- Test / Monitor mode - Similar to run mode, I/O is processed, although this mode allows for monitoring, force set, resets, and more generally tuning or debugging of the system. Often monitor mode may be used as a trial for initialization. ^[2]

ID: T0858

Sub-techniques: No sub-techniques

① Tactics: [Execution](#), [Evasion](#)

① Platforms: None

Version: 1.0

Created: 21 May 2020

Last Modified: 13 October 2023

[Version](#) [Permalink](#)

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

Procedure Examples

ID	Name	Description
S1045	INCONTROLLER	INCONTROLLER can establish a remote HTTP connection to change the operating mode of Omron PLCs. ^{[5][6]}
S1006	PLC-Blaster	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[7]
S1009	Triton	Triton has the ability to halt or run a program through the TriStation protocol. TsHi.py contains instances of halt and run functions being executed. ^[8]

Targeted Assets

ID	Asset
A0003	Programmable Logic Controller (PLC)
A0010	Safety Controller

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

Procedure Examples

ID	Name	Description
S1045	INCONTROLLER	INCONTROLLER can establish a remote HTTP connection to change the operating mode of Omron PLCs. ^{[5][6]}
S1006	PLC-Blaster	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[7]
S1009	Triton	Triton has the ability to halt or run a program through the TriStation protocol. TsHi.py contains instances of halt and run functions being executed. ^[8]

Targeted Assets

ID	Asset
A0003	Programmable Logic Controller (PLC)
A0010	Safety Controller

Visione in dettaglio di una tecnica

(Spiega cos'è, cosa fa, chi la usa, qual è il target e come ci si può difendere da essa)

Mitigations

ID	Mitigation	Description
M0801	Access Management	Authenticate all access to field controllers before authorizing access to, or modification of, a device's state, logic, or programs. Centralized authentication techniques can help manage the large number of field controller accounts needed across the ICS.
M0800	Authorization Enforcement	All field controllers should restrict operating mode changes to only required authenticated users (e.g., engineers, field technicians), preferably through implementing a role-based access mechanism. Further physical mechanisms (e.g., keys) can also be used to limit unauthorized operating mode changes.
M0802	Communication Authenticity	Protocols used for device management should authenticate all network messages to prevent unauthorized system changes.
M0804	Human User Authentication	All field controllers should require users to authenticate for all remote or local management sessions. The authentication mechanisms should also support Account Use Policies , Password Policies , and User Account Management .
M0807	Network Allowlists	Use host-based allowlists to prevent devices from accepting connections from unauthorized systems. For example, allowlists can be used to ensure devices can only connect with master stations or known management/engineering workstations. ^[6]
M0930	Network Segmentation	Segment operational network and systems to restrict access to critical system functions to predetermined management systems. ^[6]
M0813	Software Process and Device Authentication	Authenticate connections from software and devices to prevent unauthorized systems from accessing protected management functions.

Detection

ID	Data Source	Data Component	Detects
DS0015	Application Log	Application Log Content	Monitor device application logs which may contain information related to operating mode changes, although not all devices produce such logs.
DS0029	Network Traffic	Network Traffic Content	Monitor ICS management protocols for functions that change an asset's operating mode.
DS0040	Operational Databases	Device Alarm	Monitor alarms for information about when an operating mode is changed, although not all devices produce such logs.

Visione in dettaglio di un attacco

(Spiega chi è, cosa fa e su quali tecniche si basa)

Procedure Examples

ID	Name	Description
S1045	INCONTROLLER	INCONTROLLER can establish a remote HTTP connection to change the operating mode of Omron PLCs. ^{[5][6]}
S1006	PLC-Blaster	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[7]
S1009	Triton	Triton has the ability to halt or run a program through the TriStation protocol. TsHi.py contains instances of halt and run functions being executed. ^[8]

Targeted Assets

ID	Asset
A0003	Programmable Logic Controller (PLC)
A0010	Safety Controller

Visione in dettaglio di un attacco

(Spiega chi è, cosa fa e su quali tecniche si basa)

PLC-Blaster

PLC-Blaster is a piece of proof-of-concept malware that runs on Siemens S7 PLCs. This worm locates other Siemens S7 PLCs on the network and attempts to infect them. Once this worm has infected its target and attempted to infect other devices on the network, the worm can then run one of many modules. ^{[1] [2]}

ID: S1006

① Type: MALWARE

Version: 1.0

Created: 26 March 2019

Last Modified: 12 October 2022

[Version](#) [Permalink](#)

ATT&CK® Navigator Layers

Techniques Used

Domain	ID	Name	Use
ICS	T0858	Change Operating Mode	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[1]
ICS	T0814	Denial of Service	The execution on the PLC can be stopped by violating the cycle time limit. The PLC-Blaster implements an endless loop triggering an error condition within the PLC with the impact of a DoS. ^[1]
ICS	T0835	Manipulate I/O Image	PLC-Blaster may manipulate any outputs of the PLC. Using the POU POKE any value within the process image may be modified. ^[1]
ICS	T0821	Modify Controller Tasking	PLC-Blaster's code is stored in OB9999. The original code on the target is untouched. The OB is automatically detected by the PLC and executed. ^[1]
ICS	T0889	Modify Program	PLC-Blaster copies itself to various Program Organization Units (POU) on the target device. The POUs include the Data Block, Function, and Function Block. ^[1]
ICS	T0834	Native API	PLC-Blaster uses the system function blocks TCON and TDISCON to initiate and destroy TCP connections to arbitrary systems. Buffers may be sent and received on these connections with TRCV and TSEND system function blocks. ^[1]
ICS	T0843	Program Download	PLC-Blaster utilizes the PLC communication and management API to load executable Program Organization Units. ^[1]
ICS	T0846	Remote System Discovery	PLC-Blaster scans the network to find other Siemens S7 PLC devices to infect. It locates these devices by checking for a service listening on TCP port 102. ^[1]

Visione in dettaglio di un attacco

(Spiega chi è, cosa fa e su quali tecniche si basa)

PLC-Blaster

PLC-Blaster is a piece of proof-of-concept malware that runs on Siemens S7 PLCs. This worm locates other Siemens S7 PLCs on the network and attempts to infect them. Once this worm has infected its target and attempted to infect other devices on the network, the worm can then run one of many modules. ^{[1] [2]}

ID: S1006

① Type: MALWARE

Version: 1.0

Created: 26 March 2019

Last Modified: 12 October 2022

[Version](#) [Permalink](#)

ATT&CK® Navigator Layers

Techniques Used

Domain	ID	Name	Use
ICS	T0858	Change Operating Mode	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[1]
ICS	T0814	Denial of Service	The execution on the PLC can be stopped by violating the cycle time limit. The PLC-Blaster implements an endless loop triggering an error condition within the PLC with the impact of a DoS. ^[1]
ICS	T0835	Manipulate I/O Image	PLC-Blaster may manipulate any outputs of the PLC. Using the POU POKE any value within the process image may be modified. ^[1]
ICS	T0821	Modify Controller Tasking	PLC-Blaster's code is stored in OB9999. The original code on the target is untouched. The OB is automatically detected by the PLC and executed. ^[1]
ICS	T0889	Modify Program	PLC-Blaster copies itself to various Program Organization Units (POU) on the target device. The POUs include the Data Block, Function, and Function Block. ^[1]
ICS	T0834	Native API	PLC-Blaster uses the system function blocks TCON and TDISCON to initiate and destroy TCP connections to arbitrary systems. Buffers may be sent and received on these connections with TRCV and TSEND system function blocks. ^[1]
ICS	T0843	Program Download	PLC-Blaster utilizes the PLC communication and management API to load executable Program Organization Units. ^[1]
ICS	T0846	Remote System Discovery	PLC-Blaster scans the network to find other Siemens S7 PLC devices to infect. It locates these devices by checking for a service listening on TCP port 102. ^[1]

Visione in dettaglio di un attacco

(Spiega chi è, cosa fa e su quali tecniche si basa)

PLC-Blaster

PLC-Blaster is a piece of proof-of-concept malware that runs on Siemens S7 PLCs. This worm locates other Siemens S7 PLCs on the network and attempts to infect them. Once this worm has infected its target and attempted to infect other devices on the network, the worm can then run one of many modules.^{[1] [2]}

ID: S1006

① Type: MALWARE

Version: 1.0

Created: 26 March 2019

Last Modified: 12 October 2022

[Version](#) [Permalink](#)

ATT&CK® Navigator Layers

Techniques Used

Domain	ID	Name	Use
ICS	T0858	Change Operating Mode	PLC-Blaster stops the execution of the user program on the target to enable the transfer of its own code. The worm then copies itself to the target and subsequently starts the target PLC again. ^[1]
ICS	T0814	Denial of Service	The execution on the PLC can be stopped by violating the cycle time limit. The PLC-Blaster implements an endless loop triggering an error condition within the PLC with the impact of a DoS. ^[1]
ICS	T0835	Manipulate I/O Image	PLC-Blaster may manipulate any outputs of the PLC. Using the POU POKE any value within the process image may be modified. ^[1]
ICS	T0821	Modify Controller Tasking	PLC-Blaster's code is stored in OB9999. The original code on the target is untouched. The OB is automatically detected by the PLC and executed. ^[1]
ICS	T0889	Modify Program	PLC-Blaster copies itself to various Program Organization Units (POU) on the target device. The POUs include the Data Block, Function, and Function Block. ^[1]
ICS	T0834	Native API	PLC-Blaster uses the system function blocks TCON and TDISCON to initiate and destroy TCP connections to arbitrary systems. Buffers may be sent and received on these connections with TRCV and TSEND system function blocks. ^[1]
ICS	T0843	Program Download	PLC-Blaster utilizes the PLC communication and management API to load executable Program Organization Units. ^[1]
ICS	T0846	Remote System Discovery	PLC-Blaster scans the network to find other Siemens S7 PLC devices to infect. It locates these devices by checking for a service listening on TCP port 102. ^[1]

Cyber Kill Chain e MITRE ATT&CK

(Differenze principali)

- Seppur simili e molto sovrapponibili, Cyber Kill Chain e ATT&CK hanno parecchie differenze chiave:
 - Focus e Prospettiva
 - Profondità
 - Applicazioni e casi d'uso
 - Update

Cyber Kill Chain e MITRE ATT&CK

(Differenza principale: Focus e Prospettiva)

- **Cyber Kill Chain:** focus sugli stadi dell'attacco dalla prospettiva dall'attaccante. Alto livello
- **MITRE ATT&CK:** focus sulle tecniche di attacco utilizzate dagli attaccanti. Basso livello, permette di comprendere l'attività dell'attaccante fino al dettaglio delle tattiche d'attacco

Cyber Kill Chain e MITRE ATT&CK

(Differenza principale: Profondità)

- **Cyber Kill Chain:** fornisce una Scaletta chiara e concise delle fasi di un attacco
- **MITRE ATT&CK:** fornisce una descrizione chiara e concisa delle tecniche utilizzate dagli attaccanti, fornendo anche spunti su strategie di mitigazione e di rilevazione

Cyber Kill Chain e MITRE ATT&CK

(Differenza principale: Applicazioni e casi d'uso)

- **Cyber Kill Chain:** utilizzata nelle fasi iniziali della threat detection e prevention, con lo scopo principale di identificare potenziali minacce e impedire che causino danni
- **MITRE ATT&CK:** utilizzata lungo tutto il ciclo di vita di sicurezza

Cyber Kill Chain e MITRE ATT&CK

(Differenza principale: Update)

- **Cyber Kill Chain:** sviluppata da Lockheed Martin e aggiornata sporadicamente
- **MITRE ATT&CK:** sviluppo community-driven (mantenuto da MITRE) e aggiornata continuamente

Cyber Kill Chain e MITRE ATT&CK

(Focus del corso)

Cyber Kill Chain

1. Recon-
naissance

2. Weapon-
ization

MITRE ATT&CK

Initial Access 10 techniques	Execution 14 techniques	Persistence 20 techniques	Privilege Escalation 14 techniques
Content Injection	Cloud Administration Command	Account Manipulation (8)	Abuse Elevation Control Mechanism (8)
Drive-by Compromise	Command and Scripting Interpreter (10)	BITS Jobs	Access Token Manipulation (3)
Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (8)
External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (3)	Boot or Logon Autostart Execution (14)
Hardware Additions	Exploitation for Client Execution	Browser Extensions	Boot or Logon Initialization Scripts (3)
Phishing (4)	Inter-Process Communication (2)	Compromise Host Software Binary	Create or Modify System Process (3)
Replication Through Removable Media	Native API	Create Account (2)	Domain or Tenant Policy Modification (2)
Supply Chain Compromise (2)	Scheduled Task/Job (3)	Create or Modify System Process (3)	Event Triggered Execution (18)
Trusted Relationship	Serverless Execution	Event Triggered Execution (18)	Escape to Host
Valid Accounts (4)	Shared Modules	External Remote Services	Event Triggered Execution (18)
	Software Deployment Tools	Hijack Execution Flow (13)	Exploitation for Privilege Escalation
	System Services (2)	Implant Internal Image	Hijack Execution Flow (13)
	User Execution (2)	Modify Authentication Process (8)	Process Injection (12)
	Windows Management Instrumentation	Office Application Startup (8)	Scheduled Task/Job (3)
		Power Settings	Valid Accounts (4)
		Pre-OS Boot (5)	
		Scheduled Task/Job (3)	
		Server Software Component (3)	
		Traffic Signalling (2)	
		Valid Accounts (4)	

Vulnerabilità Software

Software e bug

- **Tutti i software hanno dei bug.** Alcuni di essi sono *funzionali*, mentre altri sono creati per elevare i privilegi, permettere la fuoriuscita di informazioni, e/o causare negazioni di servizio. Gli ultimi tipi di bug sono quelli cui ci riferiamo come ***vulnerabilità software di sicurezza***
- Queste vulnerabilità sono scritte nel software come errori in fase di sviluppo. Se alla vigilia della messa in produzione del software non dovrebbero esserci vulnerabilità, sicuramente verranno identificate una volta che il software diventa di pubblico dominio.

Software e bug

- Quando si scoprono vulnerabilità, gli sviluppatori rilasciano patch per sistemare i bug riscontrati.
- Purtroppo questa pratica non è scontata, il che implica la possibilità di avere sistemi vulnerabili a chiunque abbia accesso al sistema e sappia sfruttare la vulnerabilità.

Perché i programmatori scrivono codice “insicuro”

- 1 Programmers do not think “multi-user”
- 2 Programmers are human, and humans are lazy. Thus, programmers will often use the “easy” approach instead of a secure approach - and once it works, they often fail to fix it later
- 3 Most programmers are simply not good programmers
- 4 Most programmers are not security people; they simply don't think like an attacker does (linear vs network)
- 5 Most computer security models are terrible
- 6 There is lots of “broken” legacy software. Fixing this software (to remove security faults or to make it work with more restrictive security policies) is difficult
- 7 Consumers don't care (enough) about security
- 8 Security costs extra development time
- 9 Security costs in terms of additional testing

ber 1998

Ciclo di vita di una vulnerabilità software

(un fornitore rilascia una nuova versione di un software con una vulnerabilità)



Ciclo di vita di una vulnerabilità software

(un attaccante rilascia un exploit, non notificando di ciò il fornitore)



Ciclo di vita di una vulnerabilità software

(il fornitore si accorge dell'exploit, in proprio o tramite segnalazioni esterne)



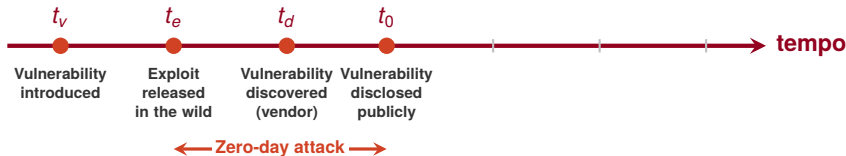
Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



- **Zero-day attack:** Nell'intero periodo $[t_e, t_0]$ l'attacco avviene in assenza di una sua pubblica conoscenza ("giorno zero" di presa di coscienza della vulnerabilità). Si parla di attacco zero-day (*zero-day attack*).

Etimologia del termine zero-day

(Warez scene, late '90s)

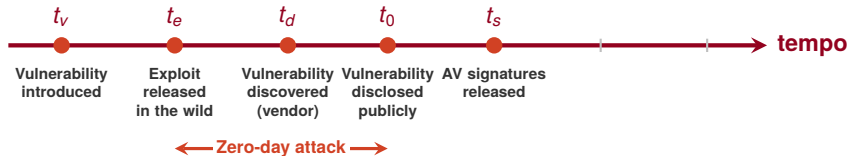
- Termine usato originalmente negli anni '90 dai cracker di software e relativi utenti (*warez scene*):

“0-day” (pronounced as zero-day)

This refers to any copyrighted work that has been released the same day as the original product, or sometimes even before. It is considered a mark of skill among warez distro groups to crack and distribute a program on the same day of its commercial release.

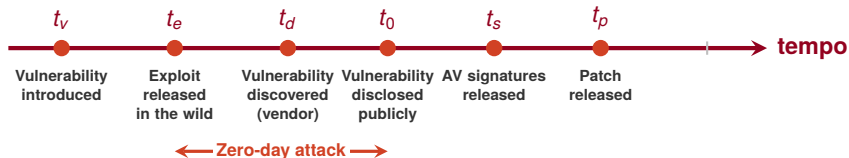
Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



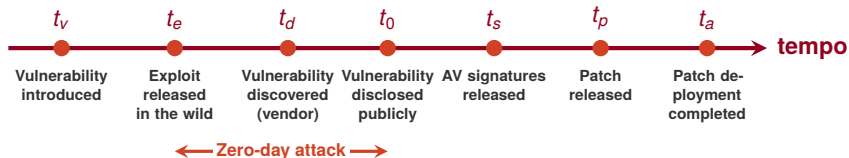
Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



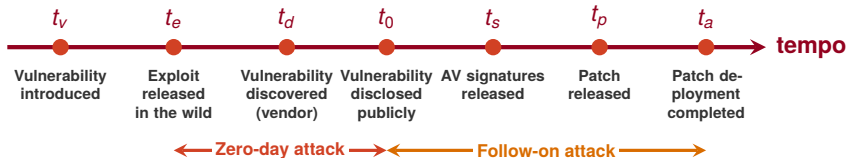
Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



Ciclo di vita di una vulnerabilità software

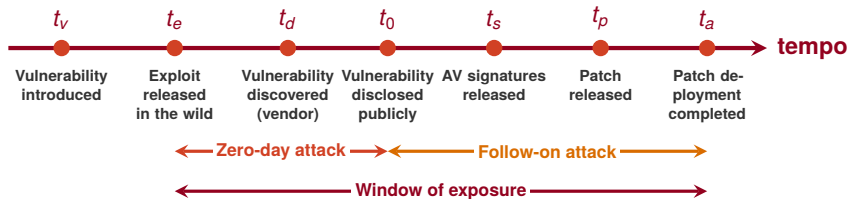
(la vulnerabilità è divulgata pubblicamente)



- **Follow-on attack:** Nell'intero periodo $[t_0, t_a]$ l'attacco avviene in presenza di una sua pubblica conoscenza. La sua forza è notevolmente ridotta rispetto al periodo $[t_e, t_0]$.

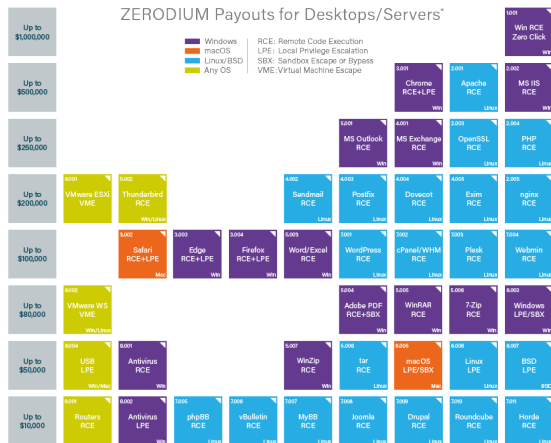
Ciclo di vita di una vulnerabilità software

(la vulnerabilità è divulgata pubblicamente)



Il costo di un exploit 0-day

(Desktops and servers, 2019 - Zerodium)

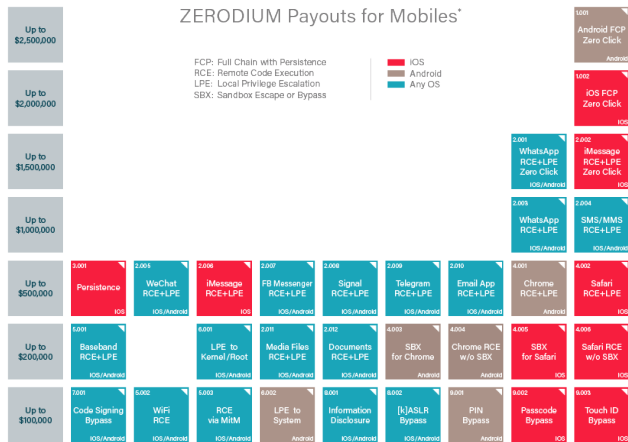


* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/01 © zerodium.com

Il costo di un exploit 0-day

(Mobile devices, 2019 - Zerodium)



* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/09 © zerodium.com

Il costo di un exploit 0-day

(Desktop edition, 2024 - Crowdfense)

OS

- **Microsoft Windows Zero Click Full Chain:** 1 M USD
- **Microsoft Windows (SBX):** 150k USD
- **Microsoft Windows (LPE):** 100k USD
- **Linux (LPE):** 100k USD
- **Apple Mac OS (LPE):** 100k USD

Browsers

- **Chrome Full Chain (RCE + v8 SBX + SBX + LPE):** 1,5 M USD
- **Firefox Full Chain (RCE + SBX + LPE):** 300k USD
- **Tor:** 500k USD

Clients / Office / Files / Archives

- **Microsoft Outlook (RCE):** 300k USD
- **Mozilla Thunderbird (RCE):** 200k USD
- **Microsoft Word/Excel (RCE):** 500k USD
- **Adobe Acrobat Reader (RCE + SBX):** 200k USD
- **WinRAR (RCE):** 100k USD
- **7-zip (RCE):** 80k USD
- **WinZip (RCE):** 50k USD

Other

- **Antivirus (RCE):** 50k USD
- **Antivirus (LPE):** 10k USD

Il costo di un exploit 0-day

(Mobile devices, 2024 - Crowdfense)

Zero Click Full Chains

- **Android Zero Click Full Chain (e.g. Whatsapp, RCS):** 5 M USD
- **iOS Zero Click Full Chain (e.g. iMessage):** from 5 to 7 M USD

Browsers

- **Chrome One Click Full Chain (RCE + v8 SBX + SBX + LPE):** from 2 to 3 M USD
- **Chrome (RCE w/o SBX):** 500k USD
- **Chrome (SBX):** 500k USD
- **Safari One Click Full Chain (RCE + SBX + LPE):** from 2,5 to 3,5 M USD
- **Safari (RCE w/o SBX):** 500k USD
- **Safari (SBX):** 500k USD

Single Components

RCE, SBX, PE (either vendor or non-vendor specific), Generic Bypass, Delivery Method or Profiling

Mobile Applications

Other apps: iCloud, Calendar, Email, Signal, FaceTime, Instagram, Telegram, Facebook, Facebook Messenger, Session, Threema, Wire, WeChat

Il costo di un exploit 0-day

(Desktop and Servers, 2025 – Advanced Security Solutions)

Microsoft Windows Windows Server, Windows Desktop Full chain \$10.000.000	Microsoft Windows Server / / / / / Local Privilege Elevation (LPE) \$100.000	Linux base OSs Desktop and Servers Full Chain \$10.000.000	Linux Server and Desktop Local Privilege Elevation (LPE) \$80.000	Other *nix OSs Desktop or Server Local Privilege Elevation (LPE) \$50.000
Apple MacOS Apple Silicon or Intel Full Chain \$7.000.000	Apple MacOS Intel Chips Local Privilege Elevation (LPE) \$100.000	Apple MacOS Apple Silicon Local Privilege Elevation (LPE) \$250.000	Virtual Machine RCE Windows, Hyper-V, QEMU/VMX, VirtualBox, Parallels Desktop \$500.000	

Microsoft IIS Full chain \$1.000.000	Nginx Remote Code Execution (RCE) \$500.000	Apache Remote Code Execution (RCE) \$500.000	Other web servers Remote Code Execution (RCE) \$100.000
--	---	--	---

Il costo di un exploit 0-day

(Mobile, 2025 – Advanced Security Solutions)

SMS / MMS (Any Mobile OS) Full chain \$20.000.000	Apple iOS Zero-click Full chain \$15.000.000	Apple iOS Safari Full chain \$5.000.000	Android Zero-click Full chain \$15.000.000	Android Google Chrome Full chain \$5.000.000
Android Snapdragon, MediaTek, Exynos, Google Tensor Local Privilege Elevation (LPE) \$500.000	Wi-Fi (Any Mobile OS) Full chain \$2.500.000	HarmonyOS Zero-click Full chain \$2.500.000	Sandbox Escape (Any Mobile OS) any part of chain \$250.000	

Welcome to the jungle

(It gets worse here everyday)



Catalogazione delle vulnerabilità

(Un'attività necessaria)

- Svariati team di sicurezza scoprono e divulgano le vulnerabilità in modo indipendente.
- Ciascun team di sicurezza costruisce un proprio archivio storico degli attacchi passati:
 - **Enumerazione:** costruzione di una tupla univoca a partire dalla vulnerabilità (es., id, tipo, vettore d'attacco, minaccia, exploit)
 - **Catalogazione:** inserimento della tupla in un apposito database

Problemi di un catalogo non uniforme

(Duplicazione degli sforzi, mancanza di interoperabilità)

- In passato, i diversi team hanno costruito altrettanti archivi storici.
- **Problemi di catalogazione indipendente:**
 - Duplicazione dello sforzo (una vulnerabilità è scoperta da più team)
 - Eterogeneità del catalogo (formati diversi, spesso non interoperabili)

Esempio: PHF phonebook CGP

(Vulnerability Tower of Babel, 1998)

- Nel 1998, la vulnerabilità PHF phonebook CGI è stata catalogata da diversi team di sicurezza nei dodici modi seguenti

Table 1 - Vulnerability Tower of Babel, 1998	
Organization	Name referring to vulnerability
AXENT (now Symantec)	phf CGI allows remote command execution
BindView	#107-cgi-phf
Bugtraq	PHF Attacks--fun and games for the whole family
CERIAS	http_escshellcmd
CERT	CA-96.06.cgi_example_code
Cisco Systems	HTTP-cgi-phf
CyberSafe	Network: HTTP 'phf' attack
DARPA	0x00000025 = HTTP PHF attack
IBM ERS	ERS-SVA-E01-1996:002.1
ISS	http-cgi-phf
Symantec	#180 HTTP server CGI example code compromises http server
SecurityFocus	#629-phf Remote Command Execution Vulnerability

La creazione di un catalogo uniforme

(Operata dal MITRE nel 1999)

- Per risolvere questo problema, nel 1999 il MITRE ha introdotto il catalogo uniforme di vulnerabilità.

The MITRE logo is displayed in a large, bold, blue sans-serif font.

Common Vulnerabilities and Exposures

(Un catalogo uniforme di vulnerabilità ed esposizioni)

- Il sistema delle **Common Vulnerabilities and Exposures (CVE)** cataloga in modo uniforme vulnerabilità ed esposizioni.
- **Vulnerabilità:** una debolezza nel software e/o nel firmware che, se sfruttata, viola almeno una tra confidenzialità, integrità, disponibilità
- **Esposizione:** un errore nel software/nella sua configurazione che permette l'accesso a funzioni ed informazioni

Identificatore CVE

(La singola vulnerabilità, opportunamente catalogata)

- Il sistema CVE implementa un database di singole vulnerabilità. Ogni vulnerabilità è rappresentata da un **identificatore CVE (CVE ID)**.
- Formato identificatore: CVE-ANNO-NUMERO
 - ANNO: l'anno in cui la vulnerabilità è stata scoperta
 - NUMERO: un numero intero progressivo
 - Es.: CVE-2023-30351

Scheda CVE

(Le informazioni associate ad ogni vulnerabilità)

- Ad ogni CVE ID corrisponde una scheda descrittiva contenente informazioni specifiche sulla vulnerabilità.
- **Description:** Una descrizione testuale del problema insito nella vulnerabilità
- **References:** Un URL descrivente in maggior dettaglio il problema (ve ne può essere più di uno)
- **Date Entry Created:** La data di inserimento della CVE nel database
- Altri campi della scheda possono essere non aggiornati nel tempo

L'archivio CVE

(Interrogabile dal sito <https://cve.mitre.org>)

- Il sito <https://cve.mitre.org> ospita l'archivio CVE, informazioni sul progetto ed un form di ricerca.
- Cliccando sul link “Search CVE List” si accede alla funzione di ricerca. È possibile cercare uno specifico CVE (*by CVE identifier*) o per parola chiave (*by keyword(s)*)
- Ad esempio, si cerchi la scheda della vulnerabilità CVE-2023-30353

La scheda di CVE-2023-30353

(Brought to you by: your professor)

CNA: MITRE Corporation

Published: 2023-05-10 Updated: 2024-08-02

Description

Shenzhen Tenda Technology IP Camera CP3 V11.10.00.2211041355 allows unauthenticated remote code execution via an XML document.

Product Status

[Learn more](#)

Information not provided

References

- https://github.com/SECloudUNIMORE/ACES/blob/master/Tenda/CP3/tmp_uRCE.md 

CVE Program

Updated: 2024-08-02

This container includes required additional information provided by the CVE Program for this vulnerability.

References

- https://github.com/SECloudUNIMORE/ACES/blob/master/Tenda/CP3/tmp_uRCE.md 

x_transferred

L'archivio CVE

(Interrogabile dal sito <https://cve.mitre.org>)

- Il sito <https://cve.mitre.org> ospita l'archivio CVE, informazioni sul progetto ed un form di ricerca.
- Cliccando sul link “Search CVE List” si accede alla funzione di ricerca. È possibile cercare uno specifico CVE (*by CVE identifier*) o per parola chiave (*by keyword(s)*)
- Ad esempio, si cerchi la scheda della vulnerabilità CVE-2023-30353

Ma le vulnerabilità sono tutte uguali?

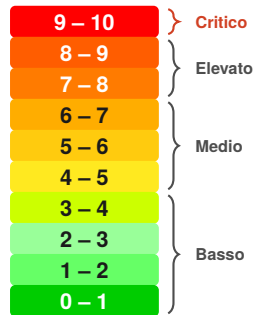
(O meglio, come si può valutare l'impatto di una vulnerabilità)

- Il sistema CVE enumera le vulnerabilità, ed è nato solo ed esclusivamente per questo scopo
- Il sistema CVE NON misura l'impatto di una vulnerabilità.
- Alcune (tristi) conseguenze:
 - Date due CVE, non si è in grado di dire quale delle due sia più urgente da gestire
 - La stessa CVE può avere un impatto diverso nel tempo
 - La stessa CVE può avere impatti diversi in sistemi operativi diversi

Common Vulnerability Scoring System

(CVSS, misura la gravità di una vulnerabilità)

- Il **Common Vulnerability Scoring System (CVSS)** è un sistema di stima della gravità di una vulnerabilità.
- Ad ogni CVE ID è assegnato un punteggio (score) da 0 a 10:
 - 0: impatto nullo
 - (0, 4): impatto basso
 - [4, 7): impatto medio
 - [7, 9): impatto elevato
 - [9, 10]: impatto critico



Versioni del CVSS

- Le versioni del sistema CSVV sono state modificate a lungo nel tempo
 - **v1**: rilasciata nel 2005, aveva diversi problemi che ne hanno impedito la diffusione
 - **v2**: rilasciata nel 2007, ha fornito una soluzione ai problemi di v1 e aveva un sistema di scoring più robusto
 - **v3**: rilasciata nel 2015, introduce nuove metriche per il calcolo dello score (privilegi, scope)
 - **v3.1**: rilasciata nel 2019, piccolo aggiornamento di v3 per semplificare e migliorare lo standard
 - **v4**: rilasciata nel novembre 2023, fornisce metriche di base dettagliate, rimuove ambiguità nel calcolo dello score e semplifica le metriche di minaccia

Le metriche CVSS v4

<https://www.first.org/cvss/specification-document>

- Il punteggio CVSS si basa su 4 gruppi di metriche:
 - Base (**Base**)
 - Minacce (**Threat**)
 - Ambiente (**Environmental**)
 - Supplementi (**Supplemental**)

Metriche Base

(Exploitability Metrics e Impact Metrics)

- Le metriche base stimano la gravità della vulnerabilità in sé, a prescindere dagli altri fattori in campo:
 - Da dove si riesce a sfruttare?
 - Quanto è semplice metterla in atto?
 - Che cosa permette di ottenere?
 - In che modo compromette il sistema?
 - <https://www.first.org/cvss/v4.0/user-guide>

Metriche Base

(Exploitability Metrics e Impact Metrics)

- **Attack Vector (AV):** contesto in cui è possibile sfruttare la vulnerabilità [*Network (N), Adjacent (A), Local (L), Physical (P)*]
- **Attack Complexity (AC):** complessità delle azioni perpetrate dall'attaccante per sfruttare la vulnerabilità [*Low (L), High (H)*]
 - Metrica che tiene conto di soluzioni di sicurezza esistenti sul sistema target
- **Attack Requirements (AT):** prerequisiti necessari per sfruttare la vulnerabilità [*None (N), Present (P)*]
- **Privilege Required (PR):** livello di privilegio richiesti dall'attaccante *prima* di poter sfruttare la vulnerabilità [*None (N), Low (L), High (H)*]
- **User Interaction (UI):** necessità di avere qualche tipo di interazione con l'utente che sta utilizzando il sistema target per sfruttare la vulnerabilità [*None (N), Passive (P), Active (A)*]

Metriche Base

(Exploitability Metrics e **Impact Metrics**)

- **Confidentiality (VC/SC):** Impatto sulla confidenzialità delle informazioni gestite dal sistema (VC) e dai sistemi collegati (SC) [*High (H)*, *Low (L)*, *None (N)*]
- **Integrity (VI/SI):** Impatto sull'integrità delle informazioni gestite dal sistema (VI) e dai sistemi collegati (SI) [*High (H)*, *Low (L)*, *None (N)*]
- **Availability (VA/SA):** Impatto sulla disponibilità delle informazioni gestite dal sistema (VA) e dai sistemi collegati (SA) [*High (H)*, *Low (L)*, *None (N)*]

Metriche di Minaccia

(Stimano la possibilità che la vulnerabilità sia sfruttabile)

- **Exploit Maturity (E):** Metrica che indica la possibilità che la vulnerabilità sia sfruttata, basata sullo stato corrente delle tecniche di sfruttamento della vulnerabilità, della disponibilità pubblica o “in-the-wild” dell’exploit:
 - **Not Defined (X)**
 - **Attacked (A)**
 - **Proof-of-Concept (P)**
 - **Unreported (U)**

Metriche Ambientali

(Stimano la gravità della vulnerabilità dal punto di vista ambientale)

- **Confidentiality/Integrity/Availability Requirements (CR/IR/AR):** Permettono di considerare l'impatto della vulnerabilità in terms di confidenzialità/integrità/disponibilità del sistema target in base alla tipologia di servizio del sistema stesso [*Not Defined (X), High (H), Medium (M), Low (L)*]

Metriche Ambientali

(Stimano la gravità della vulnerabilità dal punto di vista ambientale)

- **Modified base metrics:** Permettono di specificare le metriche Base (sia exploitability che impact) nel contesto dell'ambiente in cui la vulnerabilità viene studiata:
 - Se la Modified Base Metric ha valore Not Defined (X), allora si usa il punteggio della versione non-modified
 - Se la Modified Base Metric è definita, allora il suo valore sovrascrive quello della versione non-modified

Metriche Ambientali

(Stimano la gravità della vulnerabilità dal punto di vista ambientale)

- **Safety:** In sistemi in cui l'impatto della vulnerabilità può avere conseguenze sulla sicurezza fisica (safety), è possibile specificarla nelle metriche ambientali con valore massimo *Safety (S)*

Metriche Supplementari

(Nuovo da CVSS v4)

- Nuova sezione presente da CVSS v4, permette di specificare ulteriori metriche per descrivere e misurare ulteriori attributi espliciti di una vulnerabilità.

Metriche Supplementari

(Nuovo da CVSS v4)

- **Automatable (AU):** Cattura la risposta alla domanda “l’attaccante può automatizzare il processo di exploitation per sfruttare questa vulnerabilità?” [*Not Defined (X)*, *No (N)*, *Yes (Y)*]
- **Recovery (R):** Descrive la capacità di ripresa del sistema a seguito dell’attacco [*Not Defined (X)*, *Automatic (A)*, *User (U)*, *Irrecoverable (I)*]
- **Safety (S):** La vulnerabilità ha impatti sulla safety di un sistema che ha un uso previsto o una finalità conforme alla safety [*Not Defined (X)*, *Present (P)*, *Negligible (N)*]
 - In caso di Present (P), bisogna definire se l’impatto ha conseguenze:
 - Marginali (**Marginal**): Ferite gravi ad una o più persone
 - Critiche (**Critical**): Morte di una persona
 - Catastrofiche (**Catastrophic**): Morte di più persone

Metriche Supplementari

(Nuovo da CVSS v4)

- **Value Density (V):** Descrive le risorse che finiscono sotto il controllo dell'attaccante in un singolo evento di exploit della vulnerabilità [*Not Defined (X)*, *Diffuse (D)*, *Concentrated (C)*]
- **Vulnerability Response Effort (RE):** Fornisce informazioni aggiuntive su quanto sia difficile per i consumatori fornire una risposta iniziale all'impatto delle vulnerabilità per i prodotti e i servizi implementati nella loro infrastruttura [*Not Defined (X)*, *Low (L)*, *Moderate (M)*, *High (H)*]
- **Provider Urgency (PU):** Metrica che permette di passare informazioni sulla gravità della vulnerabilità ai consumatori attraverso la catena di sviluppo di un qualsiasi prodotto software [*Not Defined (X)*, *Red*, *Amber*, *Green*, *Clear*]
 - Manutentore della libreria → Manutentore OS/Distro → Fornitore 1 → \dots{} → Fornitore N → Consumatore

Vector String

(Ecco a cosa servono le abbreviazioni)

- Le **vector string** definite in CVSS v4 sono una semplice rappresentazione testuale di un set di metriche CVSS. Vengono comunemente utilizzate per registrare o trasferire le metriche CVSS in maniera concisa e machine-friendly.
- **NB:** Le uniche metriche **obbligatorie** sono quelle appartenenti al gruppo Base. Tutte le metriche appartenenti agli altri gruppi possono essere omesse.

Vector String

(Un esempio vale più di mille parole)

Una vulnerabilità sfruttabile dalla rete, con una complessità di attacco bassa, senza alcun requisito iniziale e che richiede privilegi elevati ma nessuna interazione utente, che ha basso impatto sulla confidenzialità, integrità e disponibilità del sistema, nessun impatto su sottosistemi e nessuna ulteriore metrica specificata che vector string produce?

Vector String

(Un esempio vale più di mille parole)

Una vulnerabilità sfruttabile dalla rete, con una complessità di attacco bassa, senza alcun requisito iniziale e che richiede privilegi elevati ma nessuna interazione utente, che ha basso impatto sulla confidenzialità, integrità e disponibilità del sistema, nessun impatto su sottosistemi e nessuna ulteriore metrica specificata che vector string produce?

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

Punteggio finale

<https://redhatproductsecurity.github.io/cvss-v4-calculator>

CVSS v4.0 calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: 5.1 / Medium ⊕

Altri approcci di catalogazione

(Molto importanti, in quanto adottati ovunque)

- I sistemi CVE e CVSS, pur con tutti i loro limiti, rappresentano un importante passo verso la creazione di un catalogo uniforme di vulnerabilità.
- Un approccio simile è stato portato avanti anche nei seguenti ambiti correlati:
 - Enumerazione degli asset hardware/software (**Common Platform Enumeration – CPE** <https://nvd.nist.gov/products/cpe>)
 - Procedure di verifica delle vulnerabilità (Open Vulnerability Assessment Language – OVAL <https://oval.mitre.org/>)
 - Enumerazione e valutazione delle debolezze software (Common Weakness Enumeration – CWE <https://cwe.mitre.org/>)

Common Weakness Enumeration

(Un catalogo uniforme di debolezze software)

- Il sistema delle **Common Weakness Enumeration (CWE)** cataloga in modo uniforme le vulnerabilità hardware e software in maniera indipendente dalla loro sfruttabilità.
- La lista CWE è sviluppata da una comunità che aggiorna costantemente (3/4 volte all'anno) la lista.

Elementi CWE

(Che cosa contiene una entry CWE)

- Ad una CWE viene assegnata un identificatore (numero univoco scelto al momento dell'inserimento) che permette di identificare univocamente l'elemento tramite la stringa **CWE-ID**
- Il CWE-ID generalmente è seguito da una nome descrittivo della debolezza (es., **CWE-121: Stack-based Buffer Overflow**)

Elementi CWE

(Che cosa contiene una entry CWE)

- Altri elementi necessari per la catalogazione di una CWE sono:
 - **Name:** include (1) il comportamento (2) la debolezza (3) la risorsa afflitta (se rilevante) e (4) la tecnologia afflitta (se rilevante)
 - **Summary:** Breve descrizione della debolezza
 - **Extended Description:** Descrizione estesa della debolezza. Questo elemento è inteso per il pubblico di persone che non hanno chiaro come la debolezza può essere sfruttata
 - **Modes of Introduction:** Come e quando la debolezza può essere stata inserita
 - **Potential Mitigations:** Una o più tecniche che eliminano e/o riducono il presentarsi o l'impatto della debolezza
 - **Common Consequences:** Impatti negativi sulla sicurezza della debolezza in caso venga sfruttata da un attaccante

Elementi CWE

(Che cosa contiene una entry CWE)

- **Applicable Platforms:** specifica linguaggi di programmazione, sistemi operativi, architetture e tecnologie nelle quali la debolezza è generalmente riscontrata
- **Demonstrative Examples:** Illustra la debolezza attraverso codice, testo esplicativo e/o diagrammi
- **Observed Examples:** Record pubblici di vulnerabilità (CVE) in prodotti reali che espongono la debolezza
- **Relationship:** Altre CWE correlate alla debolezza
- **References:** Una o più citazioni (con URL) a paper accademici, paper tecnici, blog post, presentazioni o video che descrivono la debolezza

CWE-121

(Scheda completa di CWE-121: Stack-based Buffer Overflow)

<https://cwe.mitre.org/data/definitions/121.html>

Sappiate che esiste un sistema di scoring anche per CWE (CWSS - https://cwe.mitre.org/cwss/cwss_v1.0.1.html ma che non verrà visto all'interno di questo corso)